

ISO 27001:2022

Readiness Self-Assessment Report

Company: Gap Test Co

Date: 01 June 2026

Overall Readiness: 13%

■ Needs Improvement — Significant gaps exist across multiple domains.

Executive Summary

The following table shows the readiness score for each of the 7 Annex A domains. Scores are calculated as the percentage of controls within each domain that are adequately addressed based on your responses.

Domain	Score	Status	Coverage
Organizational Controls	29%	■	2/7
People Controls	25%	■	1/4
Physical Controls	25%	■	1/4
Technological Controls	12%	■	1/8
Asset Management	0%	■	0/3
Cryptography	0%	■	0/2
Incident Management	0%	■	0/2

Overall Score: 13%

Gap Analysis by Domain

For each domain, controls that were not adequately addressed are listed below with their description and suggested next steps.

■ Organizational Controls — Score: 29% (2/7 covered)

A.5.2

Description: Information security roles and responsibilities shall be defined and allocated.

Recommended Action: Define and document information security roles (e.g., CISO, security team).
Assign responsibilities in job descriptions.

A.5.8

Description: Information security risk assessment processes shall be defined, approved and applied.

Recommended Action: Establish a formal risk assessment process. Create a risk register and define risk treatment plans.

A.5.35

Description: Internal audits shall be conducted at planned intervals to verify compliance with information security requirements.

Recommended Action: Create an internal audit programme. Conduct audits at planned intervals and track remediation.

A.5.29

Description: Business continuity plans shall be developed and maintained to ensure continuity of information security.

Recommended Action: Develop a Business Continuity Plan that covers IT systems and data recovery.

A.5.30

Description: Business continuity plans shall be tested and reviewed regularly.

Recommended Action: Schedule regular testing of business continuity plans (at least annually).
Document test results.

A.5.31

Description: Legal, statutory, regulatory and contractual requirements relevant to information security shall be identified and documented.

Recommended Action: Create a legal and compliance register. Monitor changes in data protection regulations (e.g., GDPR).

A.5.34

Description: Privacy and protection of personally identifiable information shall be ensured.

Recommended Action: Implement privacy controls for personal data. Appoint a Data Protection Officer if required.

■ People Controls — Score: 25% (1/4 covered)

A.6.1

Description: Background verification checks on all candidates for employment shall be conducted prior to joining.

Recommended Action: Implement a formal background check process for all new hires, including criminal record and reference checks.

A.6.3

Description: All personnel shall receive appropriate information security awareness training and updates.

Recommended Action: Develop a security awareness training programme including induction and annual refresher courses.

A.6.5

Description: Access rights of personnel shall be removed upon termination of their employment or contract.

Recommended Action: Create an offboarding checklist that ensures all access is revoked within 24 hours of termination.

■ Physical Controls — Score: 25% (1/4 covered)

A.7.1

Description: Physical security perimeters shall be defined and used to protect areas that contain information and other assets.

Recommended Action: Define physical security perimeters. Install access control systems (e.g., card readers, biometrics) for sensitive areas.

A.7.2

Description: Secure entry to premises and physical areas shall be controlled and protected.

Recommended Action: Implement secure entry controls, including visitor management and after-hours access restrictions.

A.7.3

Description: Visitors to secure areas shall be supervised and their access logged.

Recommended Action: Establish a visitor access policy. Require visitor registration, badges, and escorts to sensitive areas.

A.7.7

Description: Clear desk and clear screen policies shall be adopted to reduce risk of unauthorized access.

Recommended Action: Adopt a clear desk policy requiring all sensitive documents to be locked away and screens locked when unattended.

■ Technological Controls — Score: 12% (1/8 covered)

A.8.5

Description: Secure authentication methods, such as multi-factor authentication, shall be implemented where appropriate.

Recommended Action: Implement multi-factor authentication (MFA) for email, VPN, admin accounts, and remote access.

A.8.2

Description: Access to information and systems shall be revoked or modified when no longer required.

Recommended Action: Implement a process to promptly revoke or modify access when personnel change roles or leave the organization.

A.8.3

Description: Access rights shall be reviewed at regular intervals.

Recommended Action: Conduct quarterly access rights reviews. Verify that user permissions align with current job requirements.

A.8.8

Description: Security patches shall be applied in a timely manner to protect against known vulnerabilities.

Recommended Action: Establish a patch management policy. Apply critical patches within 14 days and maintain a patch schedule.

A.8.7

Description: Malware protection mechanisms shall be implemented and maintained on all endpoint devices.

Recommended Action: Deploy endpoint protection (EDR/antivirus) on all devices. Ensure definitions are updated automatically.

A.8.16

Description: Networks shall be monitored for unusual behavior and potential security incidents.

Recommended Action: Deploy network monitoring tools (SIEM/IDS/IPS) to detect and alert on unusual traffic patterns.

A.8.13

Description: Backups of information, software, and system images shall be taken and tested regularly.

Recommended Action: Implement automated backup solutions. Test restore procedures at least quarterly.

A.8.25

Description: Testing of security measures shall be conducted at planned intervals to verify effectiveness.

Recommended Action: Schedule regular penetration tests and vulnerability scans. Remediate findings based on severity.

■ Asset Management — Score: 0% (0/3 covered)

A.5.9

Description: An inventory of information assets shall be maintained and kept current.

Recommended Action: Implement an asset management system (e.g., CMDB) to maintain a current inventory of all information assets.

A.5.12

Description: Information shall be classified according to its sensitivity and criticality.

Recommended Action: Implement an information classification scheme (labels: Confidential, Internal, Public). Train staff on handling each class.

A.5.11

Description: Assets shall be returned and media disposal shall be carried out securely.

Recommended Action: Create a secure disposal policy. Use certified data destruction services for media and devices.

A.7.14

Description: Equipment containing storage media shall be verified that sensitive data has been securely erased or destroyed.

Recommended Action: Implement secure media disposal procedures including secure erase, physical destruction, and certificate of destruction.

■ Cryptography — Score: 0% (0/2 covered)

A.8.24

Description: Cryptographic controls shall be used to protect the confidentiality of information on mobile devices.

Recommended Action: Enable full-disk encryption (e.g., BitLocker, FileVault) on all laptops and mobile devices.

A.5.10

Description: Information shall be protected in transit and at rest using appropriate cryptographic methods.

Recommended Action: Identify data flows and implement encryption for sensitive data in transit and at rest.

■ Incident Management — Score: 0% (0/2 covered)

A.5.24

Description: Information security incident management processes shall be defined and applied.

Recommended Action: Develop and document an Incident Response Plan covering preparation, detection, containment, eradication, and recovery.

A.5.25

Description: Roles and responsibilities for incident response shall be assigned and documented.

Recommended Action: Assign incident response roles and ensure the team receives appropriate training.

A.5.27

Description: Information security incidents shall be documented, reported, and collected as evidence.

Recommended Action: Implement a security incident logging system. Ensure all incidents are documented with timestamps and evidence.

A.5.28

Description: Lessons learned from incidents shall be documented and used to improve the security posture.

Recommended Action: Establish a post-incident review process. Document lessons learned and update security controls accordingly.

Full Q&A; Transcript

The complete list of all 30 questions and the responses provided during the assessment.

Q1. [Q01] Do you have a documented Information Security Policy?

Answer: no we do not have that

Matched Controls: [A.5.1](#)

Q2. [Q02] Are roles and responsibilities for information security clearly defined?

Answer: no we do not have that

Matched Controls: None

Q3. [Q03] Do you have a process for managing information security risks?

Answer: no we do not have that

Matched Controls: None

Q4. [Q04] Is there a process for handling supplier/third-party security?

Answer: no we do not have that

Matched Controls: [A.5.19](#), [A.5.20](#)

Q5. [Q05] Do you conduct internal information security audits?

Answer: no we do not have that

Matched Controls: None

Q6. [Q06] Is there a business continuity plan that covers IT/data?

Answer: no we do not have that

Matched Controls: None

Q7. [Q07] Do you have a legal/compliance register for data protection laws?

Answer: no we do not have that

Matched Controls: None

Q8. [Q08] Do you conduct background checks on new employees?

Answer: no we do not have that

Matched Controls: None

Q9. [Q09] Is security training provided to all staff?

Answer: no we do not have that

Matched Controls: None

Q10. [Q10] Do employees sign confidentiality/NDA agreements?

Answer: no we do not have that

Matched Controls: [A.6.2](#)

Q11. [Q11] Is there a process for offboarding employees (revoking access)?

Answer: no we do not have that

Matched Controls: None

Q12. [Q12] Are server rooms / data centres physically secured?

Answer: no we do not have that

Matched Controls: None

Q13. [Q13] Do you control visitor access to sensitive areas?

Answer: no we do not have that

Matched Controls: None

Q14. [Q14] Is equipment protected against environmental threats?

Answer: no we do not have that

Matched Controls: [A.7.8](#)

Q15. [Q15] Do you have a clear desk and clear screen policy?

Answer: no we do not have that

Matched Controls: None

Q16. [Q16] Do you use multi-factor authentication (MFA)?

Answer: no we do not have that

Matched Controls: None

Q17. [Q17] Are access rights reviewed and revoked when no longer needed?

Answer: no we do not have that

Matched Controls: None

Q18. [Q18] Are all systems patched and updated regularly?

Answer: no we do not have that

Matched Controls: None

Q19. [Q19] Do you have antivirus / endpoint protection on all devices?

Answer: no we do not have that

Matched Controls: None

Q20. [Q20] Is network traffic monitored for threats?

Answer: no we do not have that

Matched Controls: None

Q21. [Q21] Do you have a Web Application Firewall (WAF) or similar?

Answer: no we do not have that

Matched Controls: [A.8.20](#), [A.8.21](#)

Q22. [Q22] Is data backed up regularly and tested for restore?

Answer: no we do not have that

Matched Controls: None

Q23. [Q23] Do you conduct penetration tests or vulnerability scans?

Answer: no we do not have that

Matched Controls: None

Q24. [Q24] Do you maintain an inventory of all information assets?

Answer: no we do not have that

Matched Controls: None

Q25. [Q25] Is information classified according to sensitivity?

Answer: no we do not have that

Matched Controls: None

Q26. [Q26] Do you have a policy for secure disposal of media/devices?

Answer: no we do not have that

Matched Controls: None

Q27. [Q27] Are laptops and mobile devices encrypted?

Answer: no we do not have that

Matched Controls: None

Q28. [Q28] Is sensitive data encrypted at rest and in transit?

Answer: no we do not have that

Matched Controls: None

Q29. [Q29] Do you have an incident response plan?

Answer: no we do not have that

Matched Controls: None

Q30. [Q30] Are security incidents logged and reviewed after resolution?

Answer: no we do not have that

Matched Controls: None